

Álvaro García Zafra

Propietario de la bomba: Enrique Peralbo

Contraseña: 41':8<638&\_

Pin: 0x605e

Contraseña de desbloqueo: adromicfms

Pin de desbloqueo: 13579

El primer paso que he seguido para el desbloqueo de la bomba ha sido avanzar con ni hasta que me pidieran la contraseña, después de esto he seguido avanzando y he visto que se hace una llamada a una función llamada cifrar

```
0x401256 <cifrar>      endbr64
0x40125a <cifrar+4>    mov     $0x0,%ecx
0x40125f <cifrar+9>    jmp     0x401269 <cifrar+19>
0x401261 <cifrar+11>   xor     $0x55,%edx
0x401264 <cifrar+14>   mov     %dl, (%rax)
0x401266 <cifrar+16>   add     $0x1,%ecx
0x401269 <cifrar+19>   movslq %ecx,%rax
0x40126c <cifrar+22>   add     %rdi,%rax
0x40126f <cifrar+25>   movzbl (%rax),%edx
0x401272 <cifrar+28>   test    %dl,%dl
0x401274 <cifrar+30>   jne     0x401261 <cifrar+11>
0x401276 <cifrar+32>   ret
```

He analizado esta función y me he fijado de que esta función actúa a modo de bucle, cuyo funcionamiento se basa en ir cogiendo cada uno de los bits de la contraseña que he introducido y realizarle la operación xor 0x55 a cada uno de ellos, ej, para la letra h(104 dec, 68 hex)

|               |   |                                    |
|---------------|---|------------------------------------|
| 55∨68         | = | 3D                                 |
| 3D            |   |                                    |
| Hexadecimal ▾ |   |                                    |
|               |   | 75 <sub>8</sub> = 61 <sub>10</sub> |

por lo que sustituiría la letra h por =(61 dec). Por lo que una vez supe esto me bastó con realizar la operación inversa para la contraseña dada (41':8<638&\_), xor char, 0x55, dando como resultado adromicfms

```
0x401307 <main+144>    cmp     $0x3c,%rax
0x40130b <main+148>    jle     0x401312 <main+155>
0x40130d <main+150>    call    0x401216 <boom>
0x401312 <main+155>    lea     0xddf(%rip),%rdi    # 0x4020f8
```

Seguiremos avanzando y nos encontraremos con una comparación en esta comparación se revisará si el tiempo ha pasado de 60 segundos, para evitar llamar a la bomba el contenido de eax(tiempo transcurrido) deberá ser menor de 60, para esto simplemente cambiaremos su valor a 0 y al realizar la comparación y ver que es menor realizará un salto y no llamará a boom.

Después de esto seguiremos avanzando hasta que se pida el pin, lo introduciremos y seguiremos avanzando. Habrá un punto que nos encontremos este código:

```
0x401366 <main+239> mov 0x2c(%rsp),%eax
>0x40136a <main+243> xor $0x5555,%eax
0x40136f <main+248> cmp 0x2cdb(%rip),%eax # 0x404050 <pin>
0x401375 <main+254> je 0x40137c <main+261>
0x401377 <main+256> call 0x401216 <boom>
0x40137c <main+261> lea 0x10(%rsp),%rdi
```

En esta parte lo que esta haciendo es coger el pin que he introducido y realizarle un xor con 0x5555, por lo que he observado el pin contenido en el ejecutable

```
(gdb) x/x 0x404050
0x404050 <pin>: 0x5e
(gdb) x/x 0x404051
0x404051 <pin+1>: 0x60
(gdb) x/x 0x404052
0x404052 <pin+2>: 0x00
```

como estamos en little-endian el pin será 0x605e, por lo que realizamos el xor inverso, xor 0x605e, 0x5555, y nos dará como resultado

```
350B|
Hexadecimal ▾ 324138 = 1357910
```

Por lo que de esta manera ya tendremos el pin de desbloqueo.

Una vez descubierto modifico el valor de eax, set \$eax=13579 (antes del xor, si lo hago después tendré que poner el resultado al hacerle el xor a ese numero), comparará los números y verá que son iguales, por lo que salta la bomba.

Por último realiza una última comparación de que no ha transcurrido más tiempo que el establecido como tiempo máximo, modificamos el valor al igual que antes y una vez salte esa comparación nos saldrá el mensaje de bomba desactivada.